

OWASP Juice Shop — Mini Pentest Report

Finding 1 — SQL Injection in Login Form

Severity: Critical

Affected endpoint: POST /rest/user/login

Description: The login endpoint concatenates the submitted email directly into a SQL query, so a crafted email bypasses authentication.

Impact: An attacker logs in as any user without credentials.

Steps to reproduce:

1. Browse to /#/login.
2. Submit the email ' OR 1=1-- with any password.
3. Observe that an authenticated session is returned.